

CTF Writeup: JailPS — SafePSv2

Hardened PowerShell Jail — No-Whitespace Bypass

Author: Senpai

Category: Misc / PowerShell Jail

Points: 473

Flag: SK-CERT{pow3R5H3LL_d03n7_C4r3_b0u7_5p4c3zzz}

1. Analysis

This challenge is an evolution of the previous SafePS jail. While the blacklist of forbidden words remains largely the same, the environment has been hardened with two significant changes to the echo command logic:

- **Whitespace Block:** The script now checks `$exprTrimmed -match '\s'`. If any space, tab, or newline is detected, the command is rejected.
- **Forced Prefix:** The input is now wrapped inside a literal echo command: `[ScriptBlock]::Create("echo $exprTrimmed")`.

2. Exploitation Strategy

The core vulnerability remains the use of `[ScriptBlock]::Create`, which allows for code execution. However, we had to overcome the inability to use spaces to separate the command `gv` (`Get-Variable`) from its argument `FLAG`.

The Breakthrough:

PowerShell's parser is flexible enough to distinguish between a command and its arguments if they are structurally separated by tokens like parentheses or quotes, even without a space character.

- **Reconstructing the Command:** We reused string concatenation (`"g"+"v"`) to generate the `gv` alias without triggering the `"gv"` or `"get-variable"` string filters.
- **The Call Operator:** The `&` operator executes the resulting string.
- **No-Space Argument Passing:** By placing the argument `"F*"` immediately after the command's closing parenthesis — `(&("g"+"v")"F*")` — the parser treats it as the first positional parameter for `gv`.
- **Wildcard Bypass:** Using `F*` instead of `FLAG` avoided the `"f\lag"` and `"sk"` filters in the `$BadList`.

3. Final Payload

```
(&("g"+"v")"F*")
```

Note: The outer echo is provided by the jail; the input starts at the first parenthesis.

4. Exploit in Action

The screenshot below shows the successful payload execution in the hardened SAFEPSv2 environment, with the FLAG variable value revealed:

```
(kali@ws-07)-[~/Desktop/cybergame26/26/jail-SAFEPSv2]
$ nc exp.cybergame.sk 7005
Welcome to SAFEPSv2, hardened environment.
echo ({"g"+"v"}"F*")
echo ({"g"+"v"}"F*")

Name      Value
-----
false     False
first     echo
FLAG      SK-CERT{pow3R5H3LL_d03n7_C4r3_b0u7_5p4c3zzz}
foreach
FormatEnumerationLimit 4
```

Terminal output: SAFEPSv2 returning the FLAG variable via the no-whitespace payload.

5. Flag

```
SK-CERT{pow3R5H3LL_d03n7_C4r3_b0u7_5p4c3zzz}
```